Title of the project: Integrate Zscaler with Identity Providers (IdPs) such as Azure AD

Team Members –

S.no	Name	College	Contact
1	Pranesh Rajhan SP	Sri Krishna Adithya College of Arts and Science	23bsai244pranesh rajhansp@skacas. ac.in
2	Anushkumar M	Sri Krishna Adithya College of Arts and Science	23bsai206anushku marm@skacas.ac.in
3	Ratish L	Sri Krishna Adithya College of Arts and Science	23bsai247ratishl@ skacas.ac.in
4	Tharun S	Sri Krishna Adithya College of Arts and Science	23bsai261tharuns@ skacas.ac.in

Over view: Integrating Zscaler with an Identity Provider (IdP) like Azure AD enables **identity-based authentication, Single Sign-On (SSO), and centralized user management**. This integration ensures that users are authenticated through the organization's identity system before accessing the internet or private applications through Zscaler.

---

1. Introduction

Zscaler is a cloud-based security platform that provides secure access to the internet and enterprise applications. Instead of relying only on network-based security, Zscaler uses **user identity** to apply security policies.

An **Identity Provider (IdP)** such as **Azure AD** manages user identities, authentication, and access control. By integrating Zscaler with Azure AD, organizations can enforce **Zero Trust security**, where every user must verify their identity before accessing resources.

---

2. Objectives of the Integration

The integration between Zscaler and Azure AD is implemented to achieve the following:

- Enable **Single Sign-On (SSO)** for users accessing the internet or applications through Zscaler.
- Use **centralized identity management** from Azure AD.
- Apply **security policies based on user identity and groups**.
- Support **Multi-Factor Authentication (MFA)** for stronger security.
- Automate **user provisioning and deprovisioning**.

---

3. Key Components in the Integration

Zscaler Cloud

The Zscaler platform inspects and secures user traffic. It enforces security policies such as web filtering, threat protection, and data loss prevention.

Azure AD (Identity Provider)

Azure AD authenticates users and provides identity information to Zscaler through secure protocols.

End Users

Employees or users accessing internet resources or enterprise applications.

Authentication Protocols

Common protocols used include:

- **SAML 2.0** – Used for Single Sign-On authentication.
- **SCIM** – Used for automatic user provisioning.
- **OAuth / OpenID Connect** – Used for modern identity-based authentication.

---

4. How the Integration Works

Step 1: User Access Request

A user connects to the internet through the Zscaler client or gateway.

Step 2: Authentication Redirect

If the user is not authenticated, Zscaler redirects the user to Azure AD for authentication.

Step 3: User Authentication

Azure AD verifies the user's credentials. It may require:

- Username and password
- Multi-Factor Authentication (MFA)

Step 4: SAML Assertion

After successful authentication, Azure AD sends a **SAML assertion** to Zscaler confirming the user's identity.

Step 5: Policy Enforcement

Zscaler receives the identity information and applies **security policies based on user identity, department, or group membership**.

Step 6: Secure Access

The user is allowed to access internet resources or private applications based on the defined policies.

---

5. Architecture Flow

User Device → Zscaler Client/Proxy → Zscaler

Cloud → Azure AD Authentication → Identity Assertion → Zscaler Policy Enforcement → Internet / Application Access

This architecture ensures **authentication is handled by Azure AD while Zscaler enforces security controls**.

---

6. Implementation Steps (High-Level)

Step 1: Configure SAML in Azure AD

Create a **SAML-based enterprise application** in Azure AD for Zscaler.

Step 2: Configure Zscaler as Service Provider

In the Zscaler admin portal, configure Azure AD as the **Identity Provider** and upload the IdP metadata.

Step 3: Exchange Metadata

Share metadata files between Azure AD and Zscaler to establish trust.

Step 4: Configure User Attributes

Map attributes such as:

- Username

- Email
- User groups

Step 5: Enable SSO

Enable **SAML authentication** in Zscaler and test login through Azure AD.

Step 6: Configure SCIM (Optional)

Enable SCIM provisioning to automatically sync users and groups from Azure AD to Zscaler.

---

7. Benefits of the Integration

Improved Security

- Identity-based access control
- MFA support
- Zero Trust architecture

Better User Experience

- Single Sign-On
- No repeated login prompts

Centralized Identity Management

- Manage users in one place (Azure AD)

Automated Provisioning

- Users and groups are automatically synchronized.

---

8. Use Cases

Organizations commonly use this integration for:

- Secure internet access using Zscaler Internet Access (ZIA)
- Zero Trust access to internal applications
- Remote workforce security
- Identity-based web filtering
- Conditional access policies

---

9. Conclusion

Integrating **Zscaler** with **Azure AD** enables organizations to implement **secure, identity-driven access control**. Authentication is managed by Azure AD, while Zscaler enforces security

policies and monitors traffic. This integration improves security, simplifies user management, and provides seamless access to enterprise resources.

Your Project idea:**Integration of Zscaler with Identity Providers such as Microsoft Azure Active Directory**

A **Project ID** is a unique identification code used to track and manage a project. For this project, you can assign a structured ID that reflects the technology and purpose.

1. A user tries to access the internet or an app.
2. Zscaler asks **Azure AD** to verify the user's identity.
3. Azure AD checks credentials (and MFA if enabled).
4. Once authenticated, Zscaler applies **security rules** based on the user's role or group.

Key Features:

- Single Sign-On (SSO) – one login for all apps.

- Identity-based security – rules applied per user or group.
- Multi-Factor Authentication – extra security layer.
- Automatic user provisioning – users are synced from Azure AD to Zscaler.

```
User Device
   |
v
[Zscaler Client / Browser]
   |
v
[Zscaler Cloud]
   |      \
   |       \---> If unauthenticated: Redirect to Azure
AD
   |                    |
   |                    v
   |              [Azure AD Authentication]
   |                    |
   |<---------------------- SAML Token / Assertion
   |
v
[Zscaler Policy Engine]
```

|
v
Internet / Internal Apps

ZIA-AAD-001

- ZIA – Zscaler Internet Access
- AAD – Azure Active Directory
- 001 – Project number

ZS-AUTH-2026-01

- ZS – Zscaler
- AUTH – Authentication integration
- 2026 – Year
- 01 – Project sequence number

ZTNA-ZS-AAD-01

- ZTNA – Zero Trust Network Access
- ZS – Zscaler
- AAD – Azure Active Directory

Flow Description:

1. User tries to access an app or website via Zscaler client/browser.
2. Zscaler checks if the user is authenticated.
3. If not, Zscaler redirects to **Azure AD** for authentication.
4. Azure AD verifies credentials and sends a **SAML token** back to Zscaler.
5. Zscaler reads the identity info and applies **security policies**.
6. User gains secure access to the requested resources.

Conclusion: Integrating Zscaler with Microsoft Azure Active Directory

The integration of **Zscaler** with **Azure AD** provides a modern, **identity-driven approach to cloud security**. By combining **centralized authentication** from Azure AD with **policy enforcement** in Zscaler, organizations can achieve:

- **Secure access** to the internet and internal applications for all users, including remote employees.

- **Single Sign-On (SSO)**, improving user experience while reducing credential management overhead.
- **Identity-based security policies**, applying rules based on user roles, groups, or departments.
- **Zero Trust security**, ensuring every access request is authenticated and authorized before granting access.
- **Automated user provisioning and management** through SCIM, reducing administrative effort and errors.

Vulnerability Detalis:

Vulnerability	Description	Potential Impact	Mitigation / Controls
Weak Authentication	**Users may have weak passwords or no MFA.**	**Unauthorized access, data breach.**	**Enforce strong passwords, enable Multi-Factor Authentication (MFA) through Azure AD.**

SAML Token Hijacking	SAML assertions Zscaler intercepted by attackers.	Unauthorized access to SAML resources.	Use HTTPS, signing could be encryption, and short token lifetimes.
Misconfigured Access Policies	Zscaler policies may correctly or restricted roles/groups users are .	Users gain excessive privileges access control (RBAC), and blocked.	Regular policy security audits, role-based not match user testing before deployment.
User Provisioning Errors	SCIM sync could create orphaned users.	Unauthorized access or deprovisioned users.	Enable automatic incorrect deprovisioning or fail accounts. , periodic user to remove audits, and deprovision SCIM logs monitoring.
Insider Threats	Employees with valid access.	Data exfiltration may misuse	Implement logging, credentials or policy monitoring, violations. and least privilege policies.
Phishing / Credential	Users may fall for	Compromised	User training, MFA

Theft	phishing	accounts	enforcement,	attacks to
	bypassing	and steal Azure		Zscaler
	monitoring AD controls.		suspicious credentials.	
	login activity.			

Network Data	Confidential	Enforce	Eavesdro	between ity
breach	end-to-end	pping	Zscaler,	user of sensitive
encryption				
	devices, and information. (TLS 1.2+),			
	Azure AD secure VPNs if may be			applicable.
	intercepted.			

Service	Azure AD or Users		Configure
Outage /	Zscaler	cannot	redundant
IdP	cloud	authenticat	IdPs, failover
Downtime	downtime.	e or access policies, and	
	resources.	offline access strategies.	

Improper	Security	Delayed	Enable
Logging &	events not	detection of	centralized Monitorin
captured or	attacks or	logging, alerts,	g analyzed. breaches. and
regular			
			security audit

☐

REPORT:-

Vulnerability Name:- Weak Authentication

This refers to users having weak passwords or not using Multi-Factor Authentication (MFA), which can allow unauthorized access to Zscaler-protected resources.

CWE/CVE : -

Vulnerability Name	CWE	Description
Weak Authentication	CWE -307	Improper Restriction of Excessive Authentication Attempts – weak passwords or missing MFA can allow attackers to compromise accounts.
SAML Token Hijacking	CWE -346	Origin Validation Error – improper validation of SAML tokens may allow replay or token theft.
Misconfigured Access Policies	CWE -269	Improper Privilege Management – users may get unauthorized access due to incorrect role/group mapping.
User Provisioning Errors	CWE -284	Improper Access Control – provisioning/deprovisioning errors can leave orphaned accounts.
Insider Threats	CWE -264	Permissions, Privileges, and Access Controls – misuse of legitimate privileges.
Phishing /	CWE	Weak Password Recovery

Credential -640 Mechanism – attackers exploit social Theft engineering to steal credentials.

Network CWE Cleartext Transmission of Sensitive Eavesdropp -319 Information – unencrypted data could ing be intercepted.

OWASP/SANS Category:-

OWASP Category

- **A5: Broken Access Control (2021 OWASP Top 10) – Misconfigured integration can allow unauthorized access.**
- **Identity & Authentication (OWASP ASVS v4) – Ensures proper authentication and SSO flow with IdPs.**

SANS/CWE Category

- **CWE-287: Improper Authentication – If authentication with the IdP is not enforced or validated.**

CWE-639: Authorization Bypass Through User-Controlled Key – Incorrect role mapping between IdP and Zscaler could lead to privilege escalation.

CWE-306: Missing Authentication for Critical Function – If Zscaler policies allow bypassing authentication.

Key Security Considerations

1. **SAML/SSO Configuration – Ensure SAML assertions are validated correctly.**
2. **Role/Group Mapping – Map IdP groups to Zscaler policies to enforce least privilege.**
3. **Multi-Factor Authentication (MFA) – Enable MFA in Azure AD for added security.**
4. **Session Management – Monitor token expiry and revoke access for inactive users.**

Description:-

Integrating Zscaler with an Identity Provider (IdP) like Azure Active Directory (Azure AD) allows organizations to enforce secure, centralized authentication and access control for their users when accessing cloud services. The integration typically uses SAML-based Single Sign-On (SSO), where Zscaler trusts the IdP to authenticate users and provide identity assertions.

This project focuses on integrating Zscaler with an Identity Provider such as Microsoft Azure Active Directory to provide secure authentication and centralized identity management for users accessing cloud applications.

The integration enables Single Sign-On (SSO) and secure user authentication, allowing users to access network resources and web applications through a single login. By connecting Zscaler with Azure Active Directory, organizations can enforce security policies based on user identity, group membership, and access requirements.

In this project, the configuration includes setting up SAML-based authentication, synchronizing users and groups from Azure AD, and enabling secure access control through Zscaler's cloud security platform.

Business Impact::-

The integration of Zscaler with Azure Active Directory provides significant business benefits by improving security, simplifying user access, and reducing IT management complexity.

1. Improved Security

By connecting Zscaler with Azure Active Directory, organizations can verify user identity before granting access to applications and network resources. This helps prevent unauthorized access and protects sensitive company data from cyber threats.

2. Centralized Identity Management

Azure Active Directory allows administrators to manage all user identities, roles, and permissions in one place. When integrated with Zscaler, security policies can be applied based on user identity, ensuring consistent and controlled access across the organization.

3. Single Sign-On (SSO) Convenience

Employees can log in once and securely access multiple applications without entering credentials repeatedly. This improves productivity and provides a smoother user experience.

4. Reduced IT Administrative Work

Automated user provisioning and synchronization between Azure AD and Zscaler reduce manual configuration tasks for IT teams, saving time and minimizing errors.

5. Better Compliance and Monitoring

The integration provides detailed logs and monitoring of user access activities. This helps organizations meet security and compliance requirements while improving visibility into network usage.

6. Support for Cloud-Based Work Environment

With more businesses using cloud applications and remote work environments, integrating Zscaler with Azure AD ensures secure and seamless access to applications from any location.

Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	web.mmebvba.com Fingerprint SHA256: 9e7275cb84903692044a0e1f9b64d142868901 3b68b2815791 3b7e49e778f87e Pin SHA256: mslG7Pck7m7Q7pJpb+aoqA8ouCc0eOAsVhTFBhY0M=
Common names	web.mmebvba.com
Alternative names	- INVALID
Serial Number	00ba5e79e0c2f743cb
Valid from	Mon, 25 May 2015 09:07:54 UTC
Valid until	Thu, 22 May 2025 09:07:54 UTC (expires in 1 year and 7 months)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	web.mmebvba.com Self-signed
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	No
OCSP Must Staple	No
Revocation information	None
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

Certificates provided	1 (712 bytes)
Chain issues	None

Certification Paths

Mozilla Apple Android Java Windows

Path #1: Not trusted (path does not chain to a trusted anchor)

1	Sent by server Not in trust store	web.mmebvba.com Self-signed Fingerprint SHA256: 9e7275cb84903692044a0e1f9b64d142868901 3b68b2815791 3b7e49e778f87e Pin SHA256: mslG7Pck7m7Q7pJpb+aoqA8ouCc0eOAsVhTFBhY0M= RSA 2048 bits (e 65537) / SHA256withRSA

Summary and Next Steps

Date: March 2026

Key Summary Points

- "Integration of Zscazer with Azure AD enables secure, seamless access"
- "Leverages existing identity infrastructure for Zero Trust enforcement"
- "Key success factors: proper configuration, testing, and ongoing management"
- Recommended next steps: expand to additional IdPs, enable advanced policies, schedule regular reviews"

Strategic Roadmap Ahead

- "Expand IdP ecosystem: integrate Okta, Ping Identity, and custom SAML providers"
- Enable advanced Zero Trust policies: device posture checks, adaptive risk scoring, session timeout controls"
- Institutionalize governance: quarterly review cycles, audit log retention, and policy versioning"

From integration to institutionalization — building resilient, scalable, and auditable Zero Trust access.